

Investigation

Understanding the Scenario

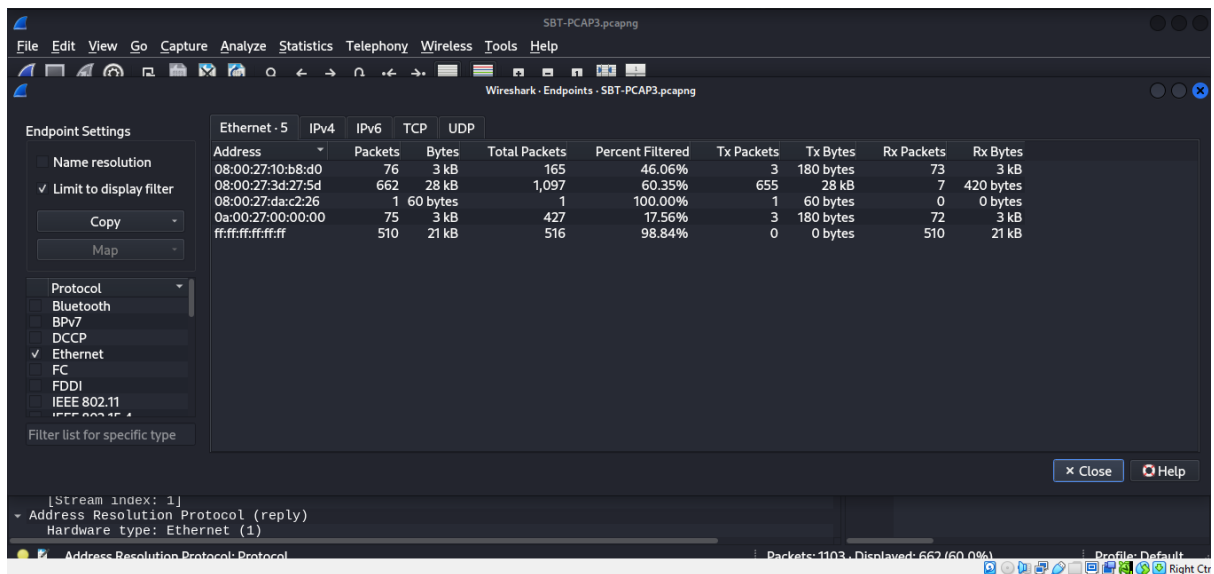
Before analysing the packet capture, I first reviewed the investigation scenario.

The scenario states that an attacker has gained physical access to the company's internal network by connecting a laptop to an unused switch port. The attacker is attempting to intercept SSH credentials exchanged between a host and the central server.

Since the attacker is able to **listen to conversations** between two legitimate hosts, this suggests that a **Man-in-the-Middle (MITM)** attack may be taking place.

One of the most common techniques used to perform a MITM attack within a local area network is **ARP spoofing (ARP poisoning)**.

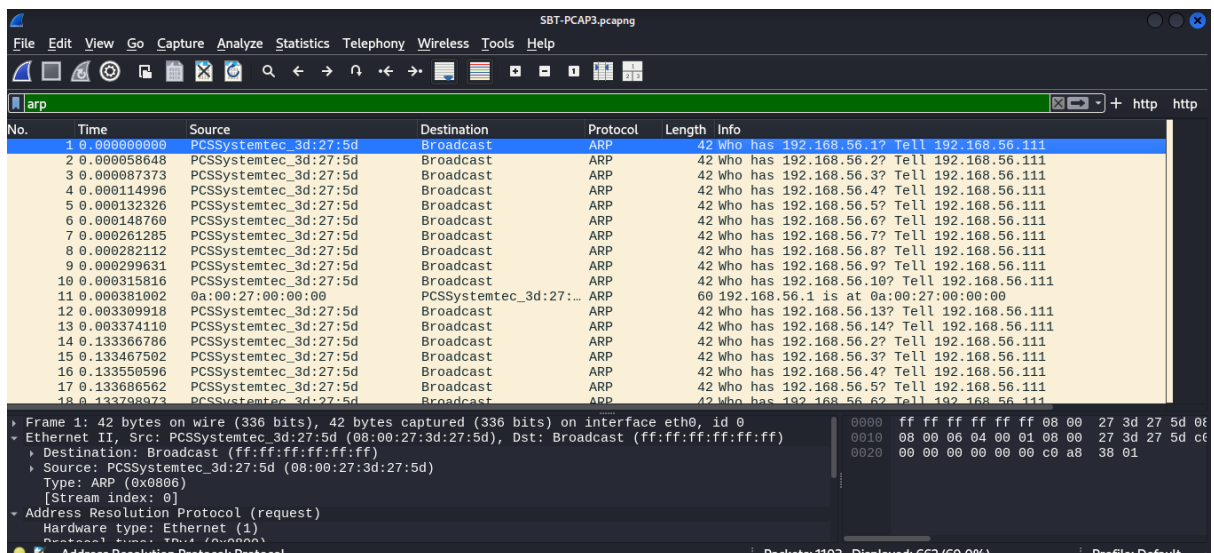




Step 1: Statistic

Using statistic > Endpoint > Ethernet. This show us there is five Mac address in this packet.

MAC Add	IP add
08:00:27:10:b8:d0	
08:00:27:3d:27:5d	
08:00:27:da:c2:26	
0a:00:27:00:00:00	



Step 2: ARP filter

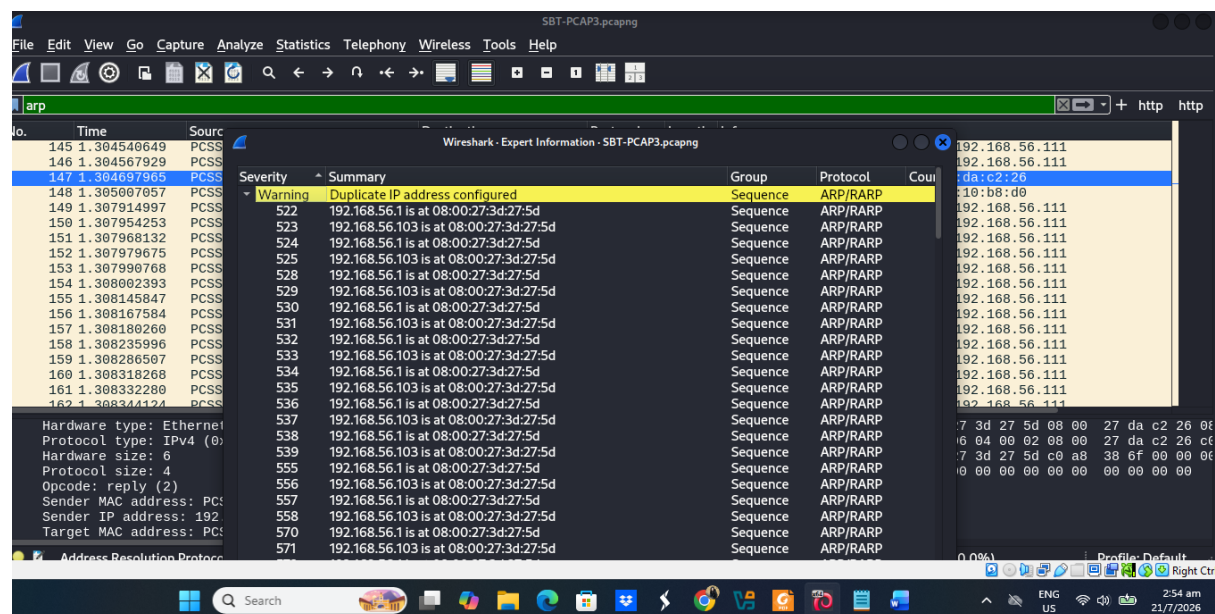
Apply the following display filter:

arp

This filter displays only ARP packets, allowing us to examine how IP addresses are mapped to MAC addresses within the local network. Below is the updated table for the mac address and ip address:

MAC Add	IP add
08:00:27:10:b8:d0	192.168.56.103
08:00:27:3d:27:5d	192.168.56.111
08:00:27:da:c2:26	192.168.56.100
0a:00:27:00:00:00	192.168.56.1

Step 3: Review Wireshark Expert Information



To quickly identify any network anomalies, navigate to:

Analyze → Expert Information

Wireshark reports the following warning:

Duplicate IP address configured

This warning indicates that the same IP address is being advertised by different MAC addresses, which is abnormal behaviour and a common indicator of ARP spoofing.

After reviewing the ARP packets, it can be observed that both **192.168.56.1** and **192.168.56.103** are repeatedly associated with the same MAC address (**08:00:27:3d:27:5d**)

Under normal circumstances, each IP address should have its own unique MAC address, and the MAC address should be:

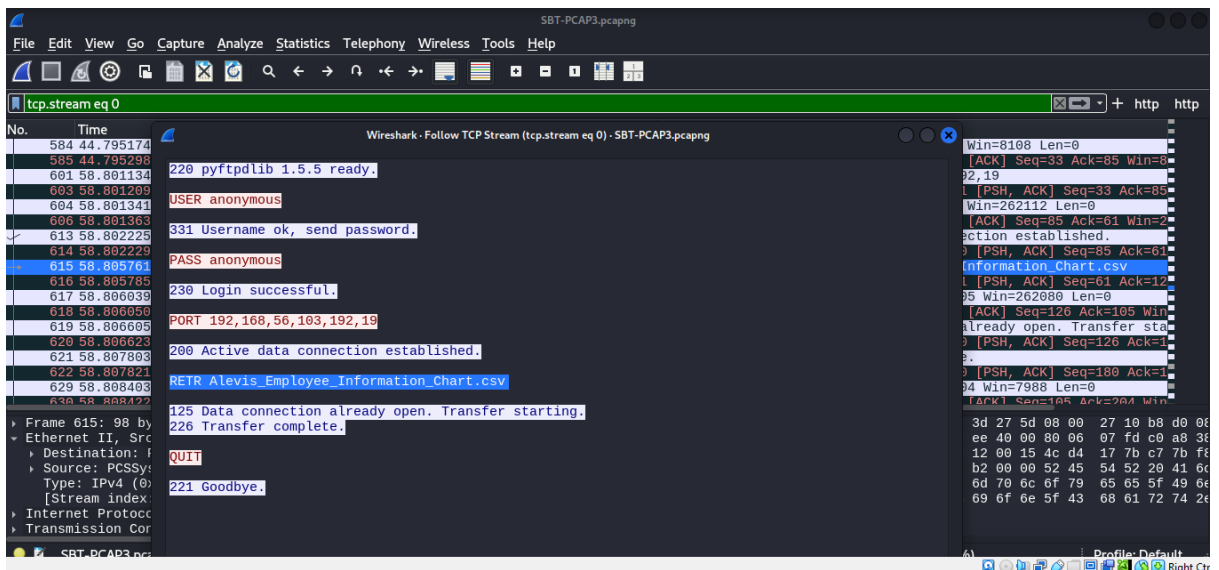
192.168.56.1 = 0a:00:27:00:00:00

192.168.56.103 = 08:00:27:10:b8:d0

The repeated advertisements strongly indicate that a MAC address (**08:00:27:3d:27:5d**) is impersonating multiple hosts on the network in order to intercept traffic.

Since the same MAC address (**08:00:27:3d:27:5d**) repeatedly claims ownership of multiple IP addresses, it can be identified as the attacker's network interface.

3. What is the file which was downloaded from the central server?



Since the investigation scenario states that the central server stores critical proprietary data, the next step is to examine file transfer activity to determine whether any sensitive files were downloaded. FTP traffic is analysed because it provides file transfer commands in plaintext, allowing downloaded files to be identified directly.

Step 1: Identify the File Transfer Protocol

Based on the investigation scenario, the attacker is attempting to collect sensitive information from the internal network. One common protocol used for file transfers is **FTP (File Transfer Protocol)**.

To identify any file transfer activity, apply the following display filter:

ftp

This filter displays only **FTP control traffic**, allowing us to examine authentication attempts, file transfer commands, and server responses while excluding unrelated network traffic.

Step 2: Inspect the FTP Session

Review the filtered FTP packets and identify the session between the FTP client and server.

Right-click on any packet within the FTP conversation and select:

Follow → TCP Stream

The **Follow TCP Stream** feature reconstructs the entire FTP control session into a single readable conversation, making it easier to analyse all commands and responses exchanged between the client and the server.

Step 3: Identify the Downloaded File

Within the reconstructed TCP stream, locate the FTP command:

RETR

The **RETR (Retrieve)** command is issued by the FTP client to request a file from the FTP server. It indicates that the specified file is being downloaded from the server to the client.

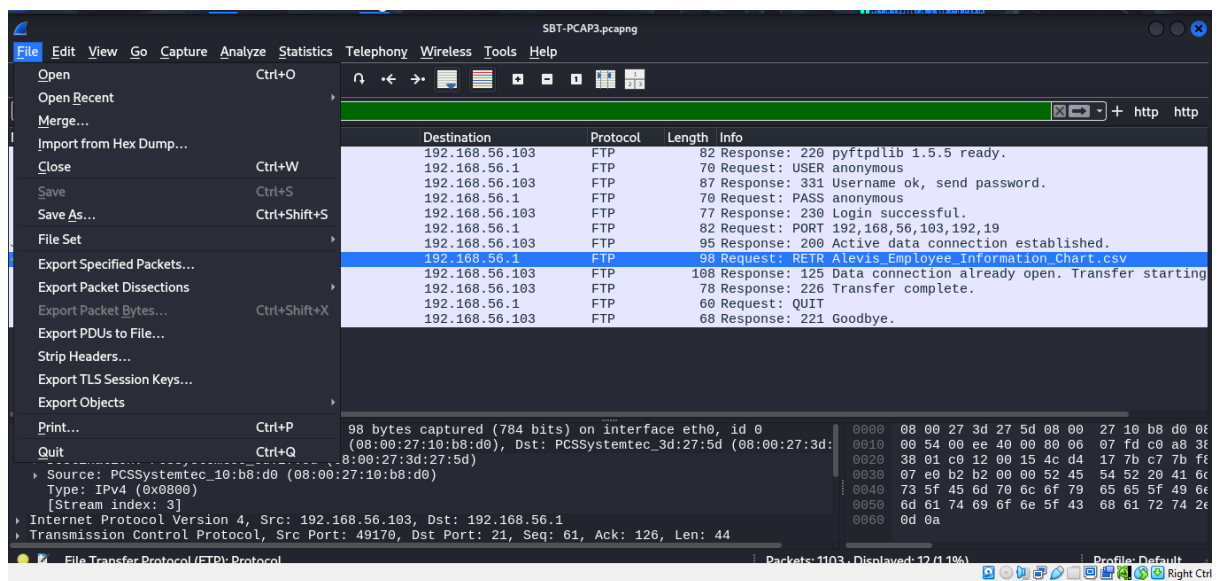
From the FTP session, the following command is observed:

RETR Alevis_Employee_Information_Chart.csv

This confirms that the downloaded file is:

Alevis_Employee_Information_Chart.csv

4. What department does Borden Danilevich work in?



722	291	Price	Dyne	pdyne82@sakura.ne.jp	Sales	27.249.251.58	pdyne82	vmA0Ayh96
723	292	Borden	Danilevich	bdanilevich83@oaic.gov.au	Sales	31.164.36.60	bdanilevich83	YKNBcV
724	293	Christophe	Hammerberg	chammerberg84@google.cn	Human Resources	122.88.98.136	chammerberg84	VSmtKli

Method 1 – Export the Downloaded CSV File

Step 1: Identify the Downloaded File

From the previous investigation, the FTP session shows that the following file was downloaded from the central server:

Alevis_Employee_Information_Chart.csv

Since the file has already been transferred over FTP, the next step is to recover its contents for further analysis.

Step 2: Export the FTP Object

Navigate to:

File → Export Objects → FTP

Wireshark lists all files transferred over the FTP session.

Select **Alevis_Employee_Information_Chart.csv**, then click **Save** to export the file to the local system.

Step 3: Open the CSV File

After exporting the file, open it using Microsoft Excel or any spreadsheet application that supports CSV files.

Search for the employee named:

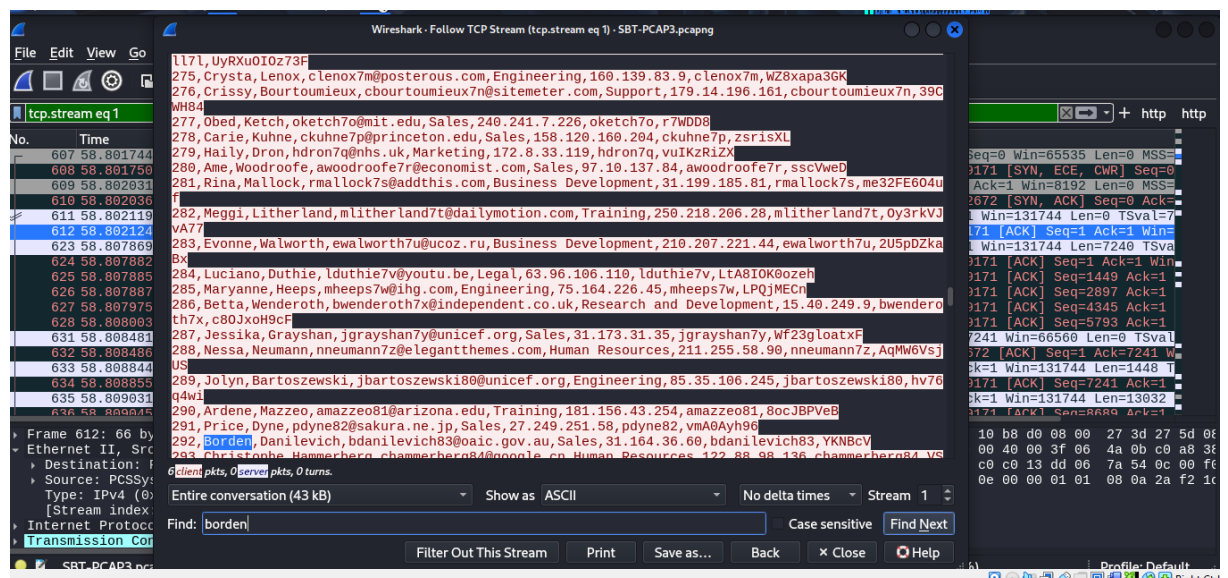
Borden Danilevich

The employee record contains several fields, including the employee's department.

From the exported CSV file, it can be confirmed that **Borden Danilevich works in the Sales department.**

Technical Explanation

The **Export Objects** feature reconstructs files transferred over supported application-layer protocols such as FTP, HTTP, SMB, and TFTP. Instead of manually reconstructing the file from packets, Wireshark automatically rebuilds the transferred object, allowing investigators to examine the original file contents directly.



Method 2 – Follow TCP Stream

Step 1: Locate the FTP Data Transfer

Identify the FTP session responsible for transferring the CSV file.

Right-click on any packet belonging to the FTP data transfer and select:

Follow → TCP Stream

Step 2: Reconstruct the FTP Conversation

The **Follow TCP Stream** feature reconstructs the entire TCP conversation into a single readable stream.

Since standard FTP transfers data in plaintext, the contents of the downloaded CSV file can be viewed directly within the TCP stream.

Step 3: Search for the Employee Record

Within the TCP Stream window, use the **Find** function and search for:

Borden

Wireshark locates the corresponding record inside the CSV data.

The employee information includes the department field, confirming that **Borden Danilevich works in the Sales department.**

Technical Explanation

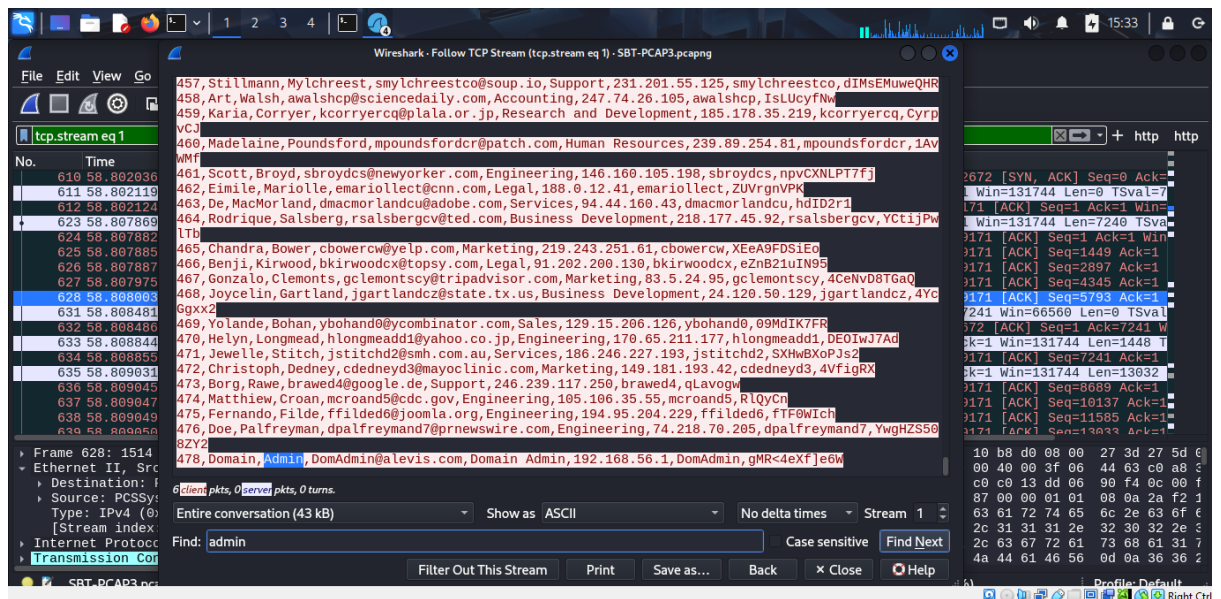
Unlike encrypted protocols, standard FTP transmits file contents in plaintext. As a result, the downloaded CSV file can be reconstructed directly from the TCP stream without requiring the file to be exported. This allows investigators to search and analyse the file contents immediately within Wireshark.

Why are there two methods?

Both methods produce the same result but serve different investigation purposes:

- **Export Objects** is the preferred approach when you need to recover the original file for offline analysis or preserve it as forensic evidence.
- **Follow TCP Stream** is faster when you only need to inspect the contents of a plaintext file or quickly search for specific information without exporting the file.

5. What is the SSH password of the Domain Administrator?



Step 1: Analyse the Downloaded Employee Information

Based on the previous investigation, the downloaded CSV file contains employee information, including usernames and other account details.

Since the objective is to identify the **SSH credentials** of the **Domain Administrator**, the next step is to locate the Domain Administrator's record within the employee database.

Based on the investigation scenario, the attacker's objective is to obtain the SSH credentials of the Domain Administrator. Therefore, the transferred employee database was examined to identify the Domain Administrator's account details.

Step 2: Inspect the FTP Data Stream

Right-click on any packet belonging to the FTP data transfer and select:

Follow → TCP Stream

The **Follow TCP Stream** feature reconstructs the entire FTP conversation, allowing the transferred CSV file to be viewed in plaintext.

Step 3: Search for the Domain Administrator

Within the TCP Stream window, use the **Find** function and search for:

admin

or

Domain Admin

The corresponding employee record contains the Domain Administrator's account information, including the username and password fields.

From this record, the SSH password of the Domain Administrator can be identified.

Technical Explanation

The transferred employee database is stored as a CSV file and transmitted over standard FTP. Since FTP does not encrypt file contents, the entire dataset can be reconstructed directly from the TCP stream.

Using the **Find** function significantly reduces the time required to locate a specific employee record instead of manually reviewing thousands of entries within the CSV file.